

Stage 2

Para iniciar con la ejecución del Stage 2 debe haberse realizado el Stage 1, para este Stage se usará ngrok que es un servicio que permite crear el servidor local en un subdominio para luego poderlo visualizar fuera de la LAN a través de internet.

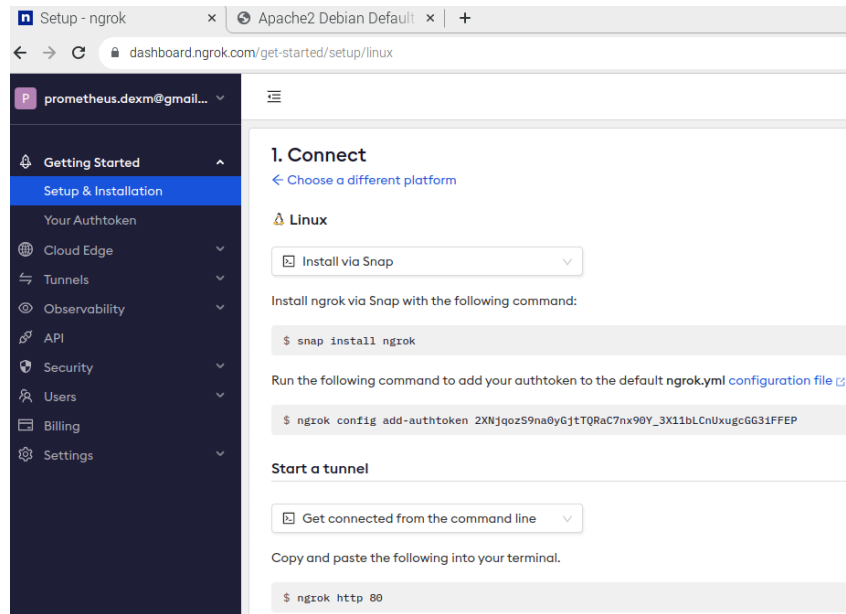


Imagen 1. Ngrok.

En el navegador del dispositivo Promedeux se encuentra en favoritos la página de ngrok para entrar en la consola de administración y ver información relevante de las conexiones, en la imagen se puede ver el proceso de instalación, sin embargo es la última línea de comando la que se va a utilizar para arrancar con el servicio, cabe señalar que los escenarios están automatizados por lo cual, para iniciar el servicio ngrok se va a hacer uso de comandos reservados que apuntan directamente con los recursos locales preconfigurados.

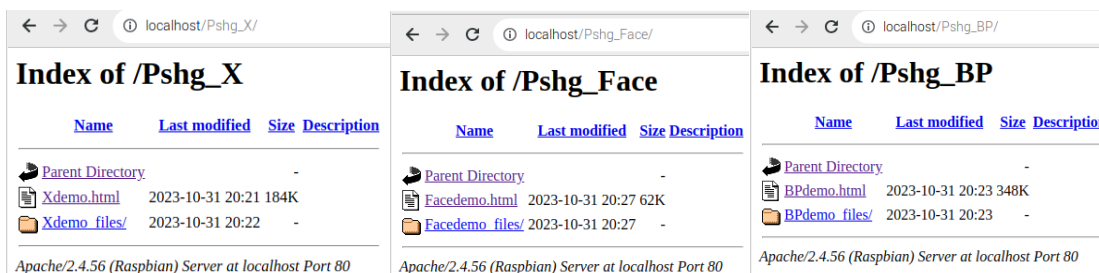


Imagen 2. Recursos locales.

El dispositivo Promedeux tiene cargadas 3 páginas web una de la red social Facebook, otra de la red social X y la última del servicio bancario de Banco de Pichincha, en el caso de esta última es necesario recordar

la línea de comando que permite ingresar a este recurso que es localhost/Pshg_BP esto se debe a que este recurso no está vinculado con el servicio de ngrok para evitar problemas de ningún tipo.

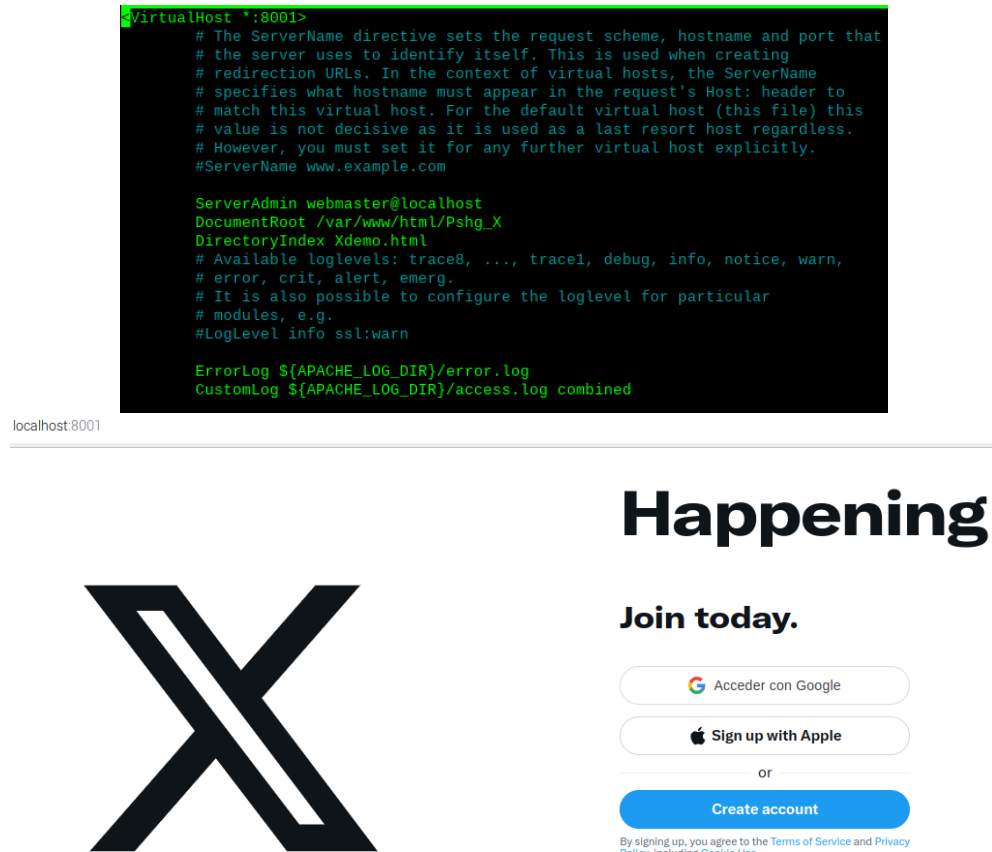


Imagen 3. Puerto 8001.

La página de la red social X está asociada al puerto 8001, en la imagen puede observarse el ingreso desde el localhost especificando el puerto 8001 usando localhost:8001.

localhost:8000

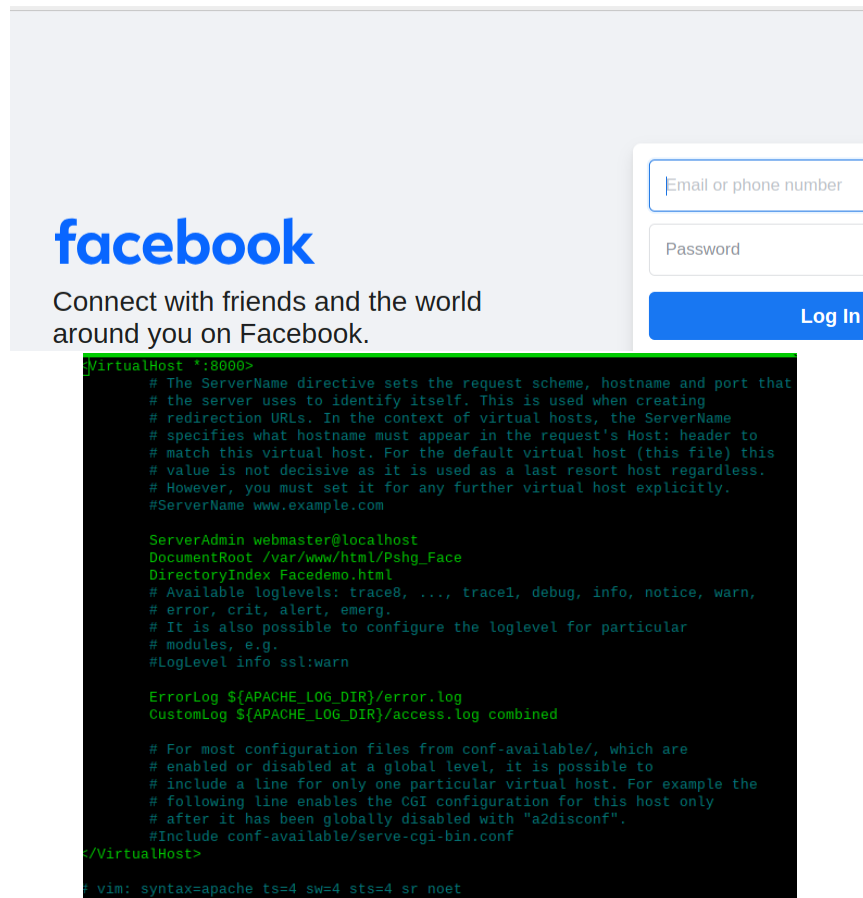


Imagen 4. Puerto 8000.

Para iniciar la página de la red social Facebook debe especificarse el puerto 8000 que está vinculado a ese recurso con el comando `localhost:8000`.

Para iniciar la demostración a los participantes se debe elegir que página se desplegara y se usara el comando reservado adecuado para iniciar el servicio ngrok.

En el caso que se desee iniciar la página de la red social X, se deberá usar el comando reservado `x` o `X` y automáticamente iniciara el servicio ngrok, se deberá esperar que el servicio genere un link público, que es el que se encuentra en el campo `forwarding`.

```
ngrok (Ctrl+C to quit)

Introducing Pay-as-you-go pricing: https://ngrok.com/r/payg

Session Status      online
Account             prometheus.dexm@gmail.com (Plan: Free)
Version             3.4.0
Region              South America (sa)
Latency              138ms
Web Interface        http://127.0.0.1:4040
Forwarding           https://f737-157-100-140-163.ngrok-free.app -> http://localhost:8001

Connections          ttl    opn    rt1    rt5    p50    p90
                    21     0      0.05   0.05   0.82   5.08

HTTP Requests
-----
GET /sw.js                                                    404 Not Found
GET /Xdemo_files/appleid.auth.js                             200 OK
GET /Xdemo_files/client                                       200 OK
GET /Xdemo_files/main.595d9dda.js                             200 OK
GET /Xdemo_files/en.6e6b21ca.js                              200 OK
GET /Xdemo_files/style                                         200 OK
GET /Xdemo_files/analytics.js                                 200 OK
GET /Xdemo_files/vendor.e761876a.js                           200 OK
GET /Xdemo_files/button.html                                  200 OK
GET /Xdemo_files/shared-loader.Typeahead-bundle.Communities-bundle.Delegate-bundle.Ocf-bundle.LoggedOutHome-bundle.Search-bund.23794d0a.js 200 OK
```

Imagen 5. Inicio ngrok.

Una vez iniciado el servicio de ngrok se debe copiar el link público en la barra de búsqueda del navegador, esta nos redirigirá a una página como se muestra en la Imagen 6. En la que se podría explicar a los participantes que no ingresen información personal, tal como advierte el servicio ngrok.

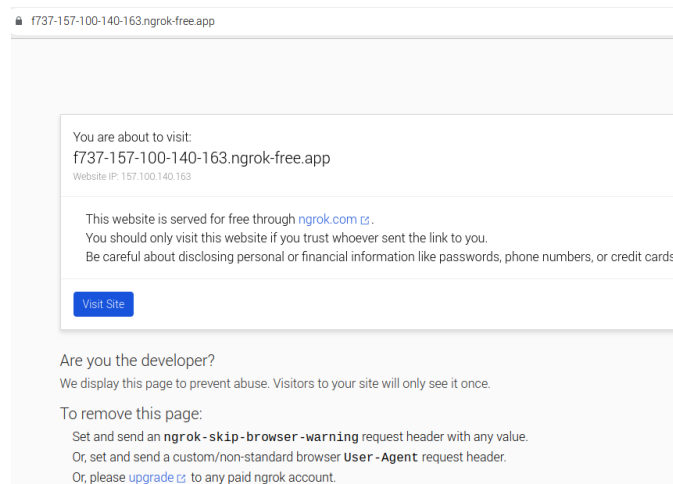


Imagen 6. Seguridad ngrok.

Se deberá acceder a la página pulsando [visit site](#), así se logrará acceder a la página seleccionada.

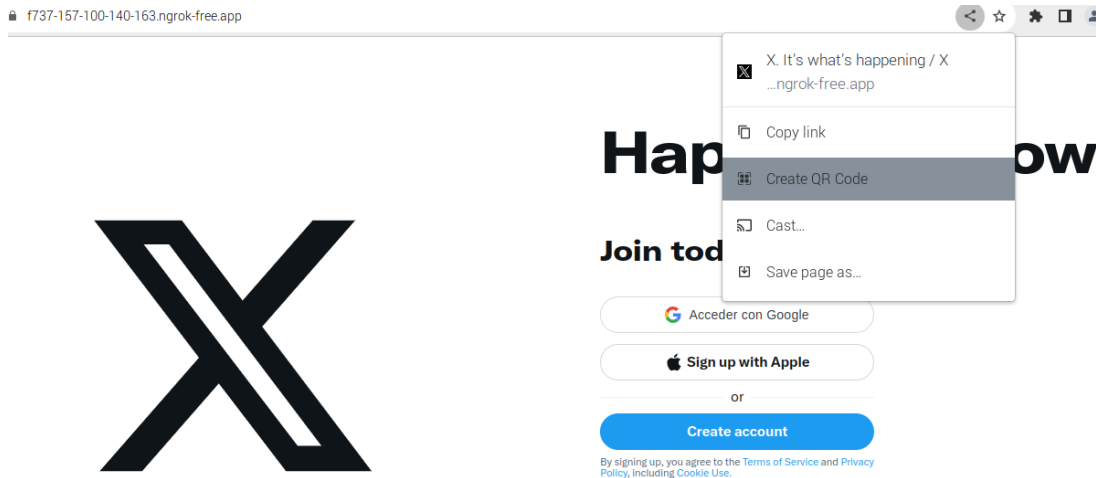


Imagen 7. Pagina X.

Una vez dentro de la página podemos notar que el link de la página contiene un identificador de ngrok, para permitir que los participantes interactúen con la página se deberá generar un código QR desde el botón compartir en la barra de búsqueda.

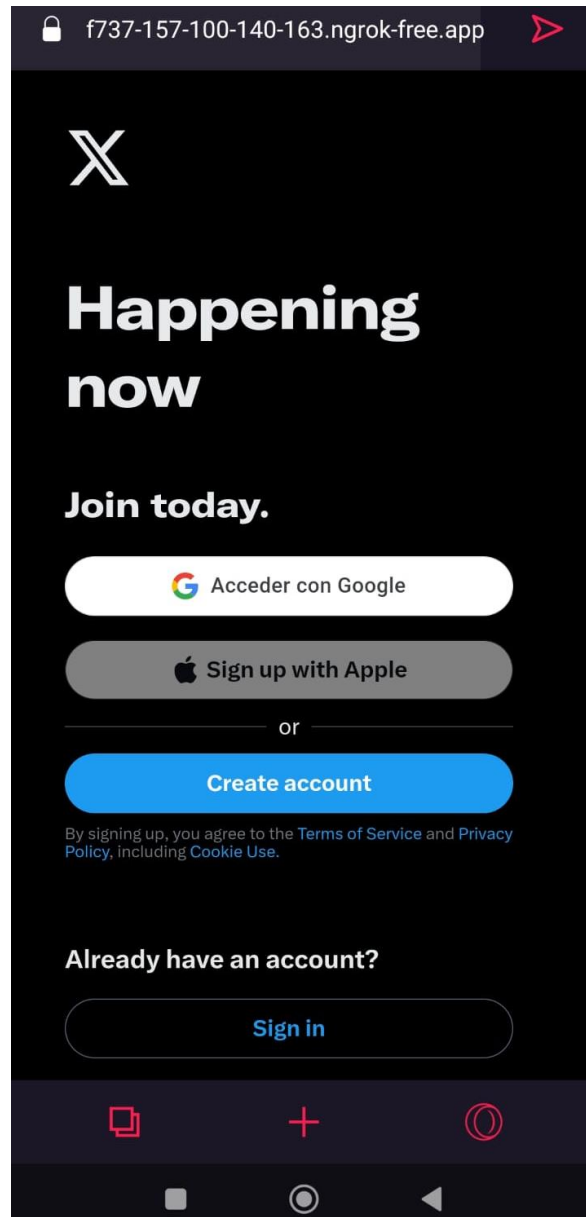


Imagen 8. Pagina X.

Se puede acceder a la página con el enlace compartido tal como se aprecia en la imagen 8, que se accedió desde un smartphone.

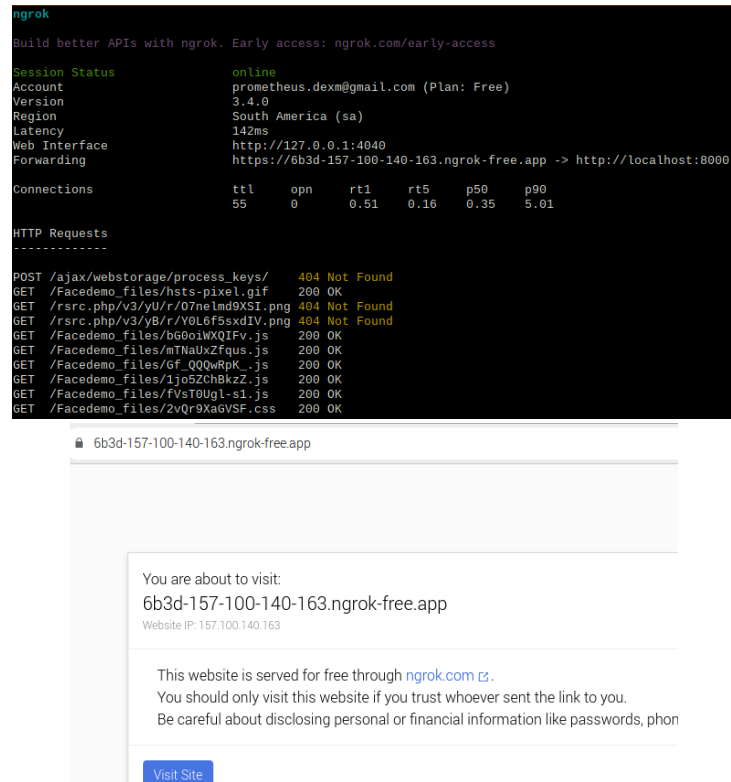


Imagen 9. Ngrok Facebook.

Podrá iniciarse también la página de Facebook, usando el comando reservado `face` o `Face` esto activará automáticamente el servicio ngrok, se deberá esperar hasta que esté disponible el link público y luego copiarlo al navegador, se mostrará el mensaje de seguridad de ngrok y se podrá acceder al contenido.

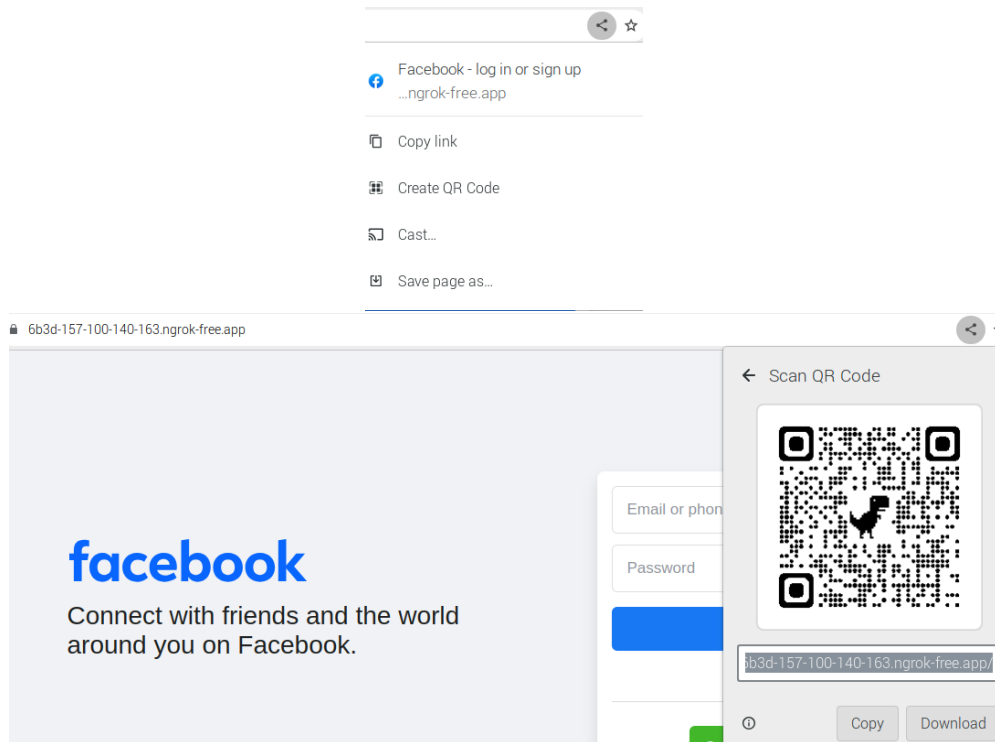


Imagen 10. Compartir QR.

En la barra de direcciones se encuentra el icono de compartir, se puede elegir crear un código QR, al seleccionarlo, tal como se puede ver en la **imagen 10**, se despliega un código QR que puede ser escaneado por los participantes para acceder a la página.

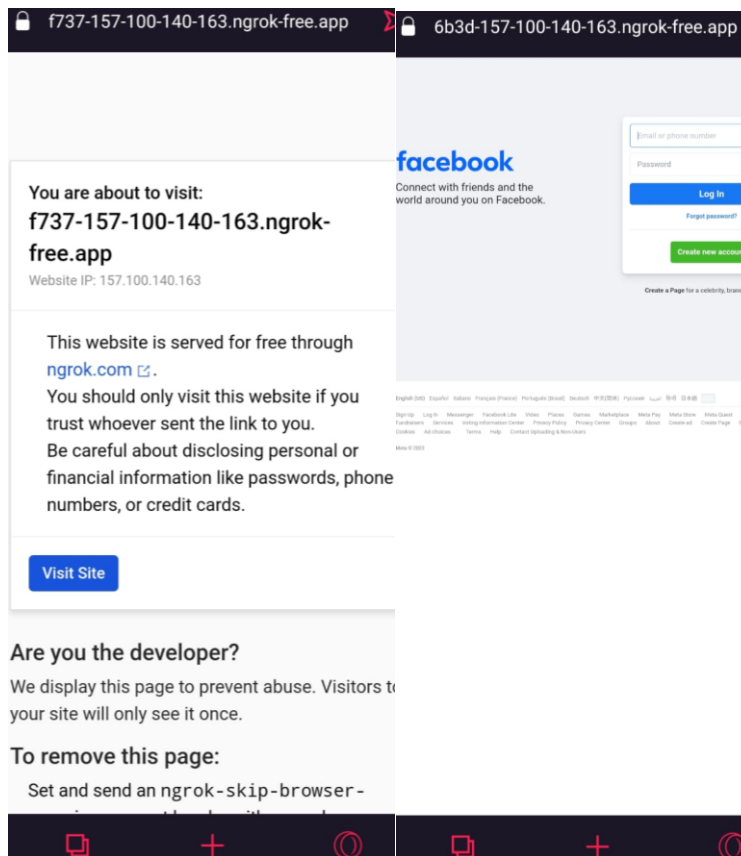


Imagen 11. Acceso QR.

En la imagen se muestra el acceso a la página desde el código QR desde un dispositivo Android.

```

epn@raspberrypi:~$ S con
Address      HWtype  HWaddress      Flags Mask    Iface
157.148.63.205      (incomplete)          wlan0
129.226.3.47       (incomplete)          wlan0
183.47.125.78      (incomplete)          wlan0
101.32.104.4       (incomplete)          wlan0
123.151.56.102     (incomplete)          wlan0
101.32.104.41      (incomplete)          wlan0
101.32.118.25      (incomplete)          wlan0
Xiaomi-11-Lite-5G-NE ether 5a:de:f7:63:2f:96 C    wlan0
120.241.190.60     (incomplete)          wlan0
121.51.162.69      (incomplete)          wlan0
^C
epn@raspberrypi:~$ S fcon
? (157.148.63.205) at <incomplete> on wlan0
? (129.226.3.47) at <incomplete> on wlan0
? (183.47.125.78) at <incomplete> on wlan0
? (101.32.104.4) at <incomplete> on wlan0
? (123.151.56.102) at <incomplete> on wlan0
? (101.32.104.41) at <incomplete> on wlan0
? (101.32.118.25) at <incomplete> on wlan0
Xiaomi-11-Lite-5G-NE (10.0.1.19) at 5a:de:f7:63:2f:96 [ether] on wlan0
? (120.241.190.60) at <incomplete> on wlan0
? (121.51.162.69) at <incomplete> on wlan0
dns.google (8.8.8.8) at <incomplete> on wlan0
dns.google (8.8.4.4) at <incomplete> on wlan0
? (43.154.240.84) at <incomplete> on wlan0
? (175.27.38.131) at <incomplete> on wlan0
? (109.244.172.79) at <incomplete> on wlan0
raspberrypi.mshome.net (192.168.137.232) at <incomplete> on wlan0
? (416.130.223.101) at <incomplete> on wlan0
LAPTOP-178JFRV9.mshome.net (192.168.137.1) at <incomplete> on wlan0
? (43.130.30.240) at <incomplete> on wlan0

```

Imagen 12. Verificación de usuarios.

Se puede verificar los usuarios conectados con el comando `con` y `fcon` para ver las conexiones generadas al estar conectados los participantes a la red del dispositivo promedex.



Imagen 13. Local host BP.

Para finalizar la demostración se debe acceder al localhost para que los participantes puedan observar los mecanismos que usan los atacantes para hacer creer a un usuario de ingresar sus contraseñas y realizar actividades delictivas.

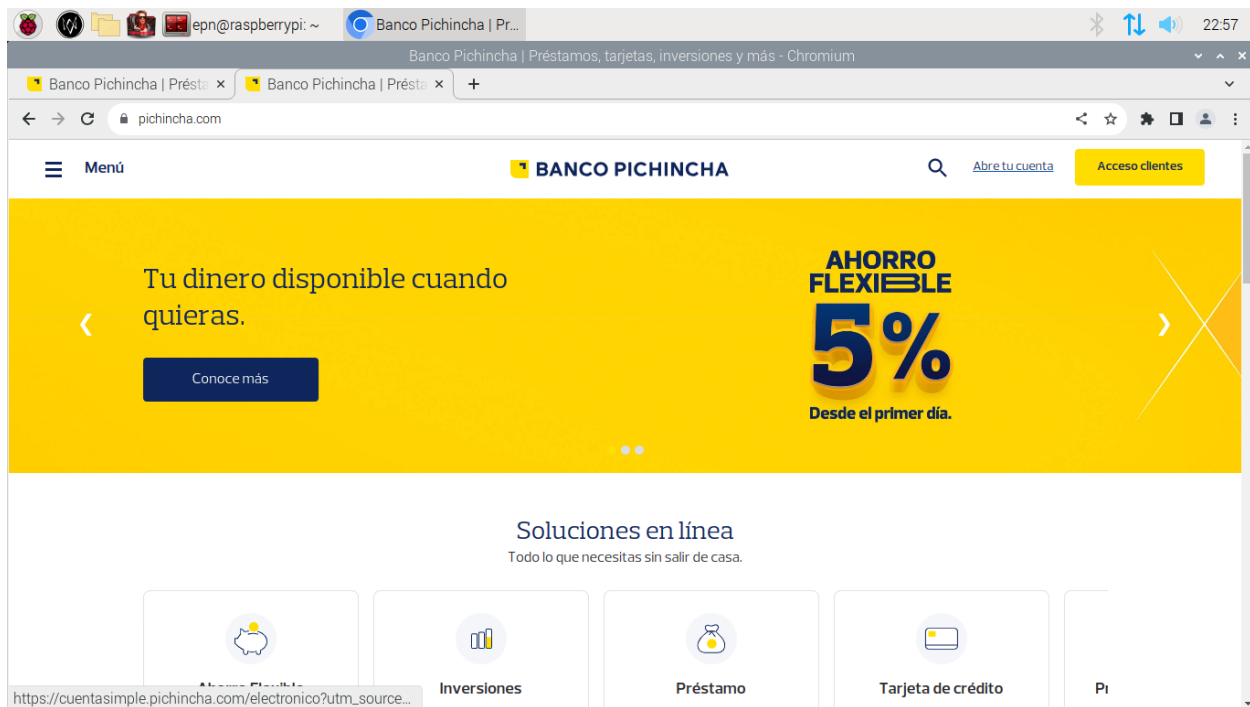


Imagen 14. Pagina real.

El expositor deberá hacer comparaciones en las páginas real y clonada haciendo que los participantes puedan ver las diferencias obvias en las páginas como los certificados y desde el mismo link de entrada.

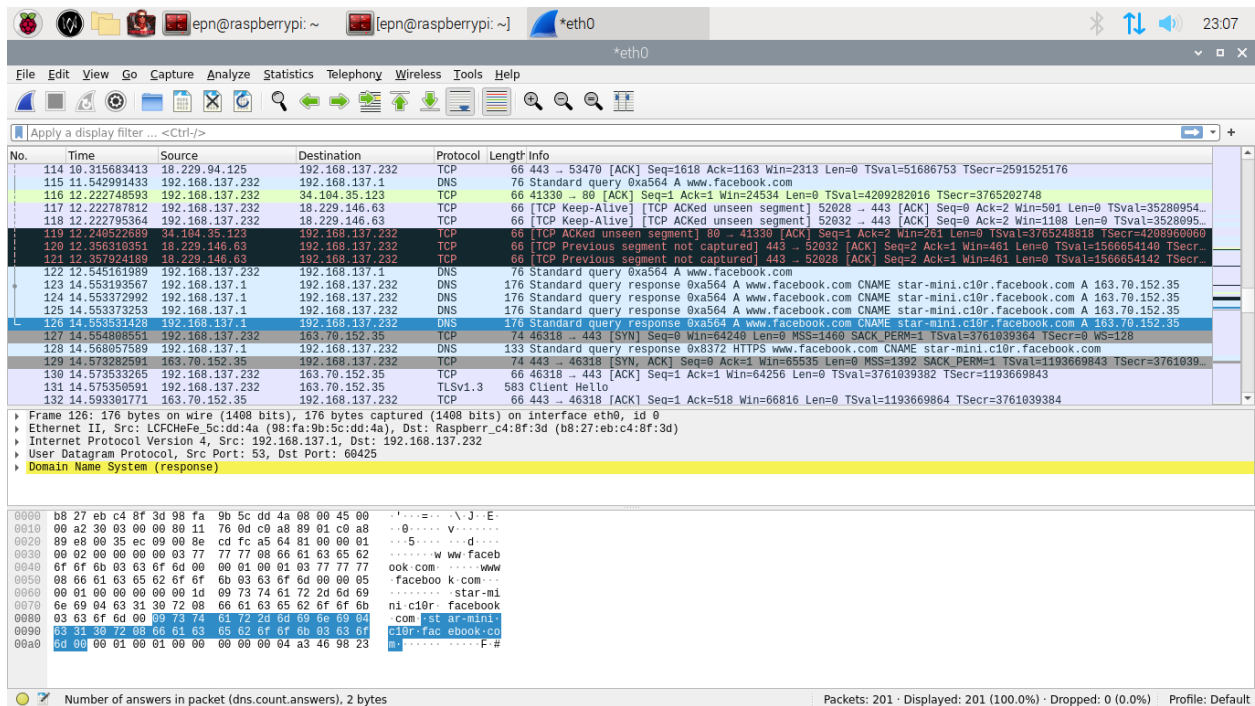


Imagen 15. Captura de tráfico.

Se puede realizar capturas de tráfico en la interacción con todas las páginas antes mencionadas para explicar a los participantes la metodología que usan los delincuentes para sustraer información personal o hacer ingeniería social para que puedan ingresar sus datos personales sin hacer sospechar a la víctima que están sustrayendo sus credenciales.

La versión offline de este Stage puede ser ejecutada ingresando a los recursos locales antes mencionados, estos se encuentran alojados en el servidor Web del dispositivo Promedeux.

Elaborado por JS.